BazarLoader Infection: Network Analysis Report

Oct 12, 2026 · @teamXdepi

Host 10.2.4.101 (DESKTOP-M551AIE, domain bogdanovtech.com) was infected on 2022-02-04 and, over 3 h 38 min of capture, ran two layers of command and control: BazarLoader check-ins to 45.41.204.156, then Cobalt Strike-style beaconing to yalileza.com and vegumihomo.com after a 1.0 MB download from the first server. No other internal host was contacted except the domain controller, and no large outbound transfer was seen.

1. Evidence reviewed

All analysis comes from one packet capture (14,476 packets, 6.82 MB) replayed through Suricata 8.0.7 and Zeek. Suricata named the capture 2022-02-04-BazarLoader-infection-with-Cobalt-Strike.pcap. All times below are UTC; Suricata's own stamps are UTC+2. Byte counts are Zeek payload bytes.

File	What it contributed
eve.json	2,242 events: 798 flow, 387 DNS, 366 SMB, 274 TLS, 164 alert, 154 DCE/RPC, 52 LDAP, 8 fileinfo, 6 anomaly, 2 Kerberos
fast.log	The same 164 alerts in one-line form; matches eve.json exactly
suricata.log, stats.log	Engine version, 53,103 rules loaded with 0 failures, 358 TCP sessions, 290 suppressed alerts
custom rules file	Five local rules, SIDs 1000101 to 1000105
conn.log, dns.log	Zeek connection and DNS records used to confirm sizes, durations and resolutions
packet_filter.log	Zeek filter was "ip or not ip", so nothing was excluded from capture
beacon_detect.py, dga_detect.py	Reviewed as detection tooling (section 5); their output files were not supplied

2. Incident timeline (UTC, 2022-02-04)

The infection unfolds in three phases: delivery and first-stage C2 (18:52 to 19:06), reconnaissance (19:06), and Cobalt Strike activity (19:42 to 19:49). BazarLoader check-ins continue until 22:26.

Time	Event	Evidence
18:52:58	First traffic: DNS and TLS to ondapro.me (Cloudflare, Let's Encrypt certificate), 5.8 KB returned	dns.log, eve TLS

Time	Event	Evidence
18:53:00	www.tqadom.com resolves to 162.0.209.40; valid Sectigo certificate; 81.9 KB returned	dns.log, eve TLS
18:54:12	194.76.227.89:443 with no DNS lookup and no SNI; self-signed certificate; 449.5 KB returned in 40s	Alerts 1000101, 1000102, 2028765
18:56:02	First session to 45.41.204.156:443 (same client fingerprint as the 18:54 download)	Alerts 1000101, 1000102, 2028765
19:06:30	Host looks up and connects to myexternalip.com	Alerts 1000103, 1000104, 2033385
19:06:35 to 19:06:57	SMB1 session over TCP 139 to the DC with an empty NTLM user, then SMB2 sessions opening the SAMR pipe (4 times) plus an LDAP search	eve smb, ldap, dcerpc
19:16:27 to 19:18:32	Five more SMB1 sessions over TCP 139 to the DC, about 30 s apart	Alert 2260002 (x5)
19:42:52	45.41.204.156 returns 999,498 bytes in 5 s; normal replies are 0.4 to 2.7 KB	conn.log, eve flow
19:43:04 / 19:43:11	DNS for yalileza.com (172.241.29.144) and vegumihomo.com (172.93.201.141); each queried once	dns.log
19:43:05 to 19:49:25	75 short TLS sessions to those two IPs, about 5 s apart	Alert 1000105 (x6)
19:48:58 to 19:49:30	Beacon request sizes change, and two more SMB2 sessions open the SAMR pipe on the DC	conn.log, eve smb
22:26:25	Last session to 45.41.204.156	eve TLS
22:30:39	End of capture; no further traffic to the Cobalt Strike servers after 19:49:25	eve flow

3. Findings

Every one of the 164 alerts involves 10.2.4.101, which is the only host with suspicious external traffic. Confidence is stated per finding because there is no endpoint evidence.

- **F1. The host is infected and remotely controlled (High).**
  134 TLS sessions to four servers that have no legitimate service behaviour: self-signed certificates, no SNI, fixed-size exchanges and machine-like timing.
- **F2. First stage matches BazarLoader tradecraft (Medium-High).**
  194.76.227.89 (CN=demir.com, Email=justin55@coleman.com) and 45.41.204.156 (CN=demirel.com, Email=krystal52@garcia.org) present self-signed certificates whose subjects look randomly generated, with no SNI and TLS 1.2. Both clients share JA3 51c64c77e60f3980eea90869b68c58a8. Suricata labels that JA3 "Dridex"; treat it as a shared fingerprint and a valid C2 indicator, not as proof of Dridex. The family call rests on the capture label and the certificate pattern.
- **F3. BazarLoader check-ins run for 3 h 30 min (High).**
  58 sessions to 45.41.204.156 between 18:56:02 and 22:26:25, a mean gap of 221 s (range 1 to 581 s), each sending 3 to 10 KB and receiving 0.4 to 2.7 KB. The jittered timing is why a simple periodicity test is not enough here.
- **F4. Host discovers its public IP (High).**
  At 19:06:30 the host queries and connects to myexternalip.com using JA3 37f463bf4616ecd445d4a1937da06e19. That is not the BazarLoader fingerprint, but it is the same one used later by the Cobalt Strike sessions, which suggests the same process or library made both.
- **F5. A second stage arrives and Cobalt Strike-style beaconing starts (Medium).**
  45.41.204.156 returned 999,498 bytes at 19:42:52, and 12 s later the host resolved yalileza.com and vegumihomo.com. Then 38 and 37 sessions alternate between 172.241.29.144 and 172.93.201.141, a median 5.3 s apart (standard deviation 1.1 s), about 0.9 KB out and 1.0 KB back each. Zeek also records one session in which 267,730 response bytes were missed, a transfer much larger than any beacon. The capture does not contain the payload, so the Cobalt Strike call rests on behaviour and the capture label.
- **F6. Domain enumeration against the DC follows C2 events (Medium).**
  The SAMR pipe on the DC is opened 9 times: once at 18:57, four times at 19:06:40 to 19:06:57 (10 s after the IP check), and four times at 19:48:58 to 19:49:30 (as beacon sizes change). Apart from those, the DC traffic is routine: Group Policy reads from SYSVOL, LDAP and DRSUAPI. Six SMB1 sessions over TCP 139 use an empty NTLM user, which is unusual for a workstation.
- **F7. No lateral movement or exfiltration is visible (Medium-High).**
  The only internal peers are the DC and DNS server 10.2.4.2 (303 flows), 10.2.4.1 (117 NetBIOS flows) and broadcast addresses. The largest single upload to any suspect server is about 10 KB. Endpoint data is needed to rule these out fully.

4. Command-and-control infrastructure

The BazarLoader channel is jittered, so detect it by certificate and TLS fingerprint. The Cobalt Strike-style channel is tightly timed, so timing rules work on it.

Server (port 443)	Role	Sessions	Cadence	Bytes up / down per session	TLS identity
194.76.227.89	First-stage download (probable)	1	Single session at 18:54:12	3.2 KB / 449.5KB	Self-signed, CN=demir.com; JA3 51c64c77…; JA3S abade5a4…
45.41.204.156	BazarLoader C2	58	Mean 221 s, range 1 to 581 s, 18:56 to 22:26	3 to 10 KB / 0.4 to 2.7 KB; one 999 KB reply at 19:42:52	Self-signed, CN=demirel.com; JA3 51c64c77…; JA3S abade5a4… and f14f2862…
172.241.29.144 (yalileza.com)	Cobalt Strike-style beacon	38	About 10.6 s per server; servers alternate	0.9 KB / 1.0 KB	SNI yalileza.com; JA3 37f463bf…; JA3S ae4edc6f…; certificate not captured
172.93.201.141 (vegumihomo.com)	Cobalt Strike-style beacon	37	About 10.6 s per server; servers alternate	0.9 KB / 1.0 KB	SNI vegumihomo.com; JA3 37f463bf…; JA3S ae4edc6f…; certificate not captured

Combined, the two beacon servers are contacted every 5.3 s (median) between 19:43:05 and 19:49:25. Neither beacon domain looks random: both are pronounceable names with a single DNS lookup, which matters for the DGA script (section 5).

5. Detection assessment

Suricata raised 164 alerts, and the local rules did most of the useful work. All 164 are true positives for this incident except the SMB protocol notices, which are noise on their own.

SID	Rule	Alerts	Assessment
2028765	ET JA3 Hash, Abuse.ch Possible Dridex	59	Correct C2 indicator, wrong family label (shared JA3)
1000102	Local: TLS to external IP without SNI	59	Precise here; will be noisy on legitimate IP-literal TLS
1000101	Local: server certificate with Email= in subject	29	High precision; fires only where the server certificate was captured
1000105	Local: 10+ new connections to one external IP in 20 min	8	Caught the Cobalt Strike servers (6) but the BazarLoader channel only twice
2260002	SURICATA protocol detected in one direction only	6	Parser noise on TCP 139, yet it marks the six null-session logins in F6
1000103, 1000104, 2033385	IP-check lookup, SNI and ET INFO rule	1 each	Correct reconnaissance indicator

Gaps and tuning

- Rule 1000105 counts new connections per destination, so the 58-session BazarLoader channel (about 5 per 20 min) fired only at 21:20 and 22:09 UTC, when bursts passed 10. Add a long-window variant, for example 15 sessions in 3 h.
- Rule 1000102 needs a second condition (JA3, certificate or no preceding DNS) before it alerts in production.
- Nothing fired on the delivery chain (ondapro.me, tqadom.com), the 999 KB second-stage download, the 267 KB gap, or JA3 37f463bf. No loaded ET rule identified the Cobalt Strike servers.
- Add detections for workstation-initiated SAMR pipe opens and for SMB1 sessions over TCP 139 with an empty NTLM user.
- stats.log reports 290 suppressed alerts, so the true event volume is higher than the 164 shown.

Python scripts (reviewed by reading the code; outputs were not supplied)

- **beacon_detect.py**
  scores channels per source, destination and port. The two alternating Cobalt Strike servers are therefore scored as two 10.6 s channels, not one 5.3 s channel. Its coverage term divides the whole capture into 24 windows, and the 6-minute burst touches only 1 or 2 of them (about 4 to

8%), which lowers its score. The BazarLoader channel covers the whole capture but is heavily jittered.

- **dga_detect.py**
  needs conn.log to reach a useful score on the beacon domains. Re-implementing its lexical formulas gives yalileza.com 19.0 and vegumihomo.com 47.3 before behaviour bonuses, against a MEDIUM threshold of 45. yalileza.com is missed by the syllabic test because it has 8 letters and the code needs at least 9 to clear its 0.5 gate. Lengthening that ramp from (len - 7) / 3 to (len - 6) / 2 fixes this. myexternalip.com scores about 66 (34.4 lexical, +20 IP-lookup keyword, +12 rare and direct-A), so the recon step is caught either way.

6. Indicators of compromise (IOC)

Values are defanged: replace . with a dot before use. Cloudflare addresses for ondapro.me are omitted because they are shared infrastructure.

Type	Indicator	Context
IP	45.41.204.156	BazarLoader C2, TCP 443, 58 sessions
IP	194.76.227.89	First-stage download, TCP 443
IP	172.241.29.144	Cobalt Strike-style C2 (yalileza.com)
IP	172.93.201.141	Cobalt Strike-style C2 (vegumihomo.com)
IP	162.0.209.40	www.tqadom.com, probable delivery stage
Domain	yalileza.com	Beacon C2, resolved 19:43:04
Domain	vegumihomo.com	Beacon C2, resolved 19:43:11
Domain	ondapro.me, tqadom.com	Probable delivery chain, first traffic in capture
Domain	myexternalip.com	External IP check (context indicator only)
Certificate	CN=demirel.com, Email=krystal52@garcia.org	Self-signed, 45.41.204.156
Certificate	CN=demir.com, Email=justin55@coleman.com	Self-signed, 194.76.227.89
JA3	51c64c77e60f3980eea90869b68c58a8	Client fingerprint of the BazarLoader stages
JA3	37f463bf4616ecd445d4a1937da06e19	Client fingerprint of the beacon and IP check; shared by other software, so use with other

Type	Indicator	Context
		signals
JA3S	abade5a4a7f42baf54766e5d108283b6	Server reply from both BazarLoader servers
JA3S	ae4edc6faf64d08308082ad26be60767	Server reply from both beacon servers
Host	DESKTOP-M551AIE, 10.2.4.101	Affected workstation in bogdanovtech.com

7. MITRE ATT&CK mapping

Technique	Observed behaviour
T1071.001 Web Protocols	C2 over HTTPS to four servers
T1573.002 Asymmetric Cryptography	TLS 1.2 with self-signed certificates (as tagged in rule 1000101)
T1105 Ingress Tool Transfer	449.5 KB at 18:54 and 999 KB at 19:42, both probable payloads
T1029 Scheduled Transfer	Fixed 5.3 s and jittered 3.7 min check-in schedules (as tagged in rule 1000105)
T1016 System Network Configuration Discovery	External IP check at 19:06:30
T1087.002, T1069.002 Domain Account and Group Discovery	SAMR pipe opens on the DC at 19:06 and 19:48 (possible, Medium confidence)

8. Recommendations

Contain now

1. Isolate DESKTOP-M551AIE (10.2.4.101). Capture memory before any reboot, since BazarLoader and Cobalt Strike configuration can be recovered from it.
2. Block the five IP addresses and four domains in section 6 at DNS, proxy and firewall.
3. Treat every account that signed in to the host as exposed. Reset those credentials and review the machine account.

Hunt

1. On the DC, review 19:06 and 19:48 UTC for SAMR access and NTLM logons with an empty user from 10.2.4.101.
2. Search proxy, DNS and flow data for other hosts that contacted the indicators, used JA3 51c64c77e60f3980eea90869b68c58a8, or received self-signed certificates with an Email= subject.
3. Find the lure: what the user opened or clicked just before ondapro.me at 18:52:58.